Mahdi Alhakim

Beirut, Lebanon · Open to relocating · U.S. citizen, no sponsorship needed
mahdi.a.alhakim@gmail.com · github.com/mahdi-al-hakim · LinkedIn · mahdi-al-hakim.github.io

Security researcher on AI agents and identity systems, and an engineer who ships MCP and agent tooling. Building for external clients since 2022. Several of my findings are checks that passed without being able to see the failure they were testing for.

AI evaluation and red-team tooling

- **microsoft/RAMPART #141** (merged, breaking change): a safety probe asserting the agent does not exfiltrate was passing while it exfiltrated every turn, because a tool-only adapter cannot observe side effects. Filed #140 and wrote the fix: evaluators now return UNDETERMINED when they cannot see the evidence they judge. Changed 4 public APIs; merged after 21 inline review comments from two maintainers. Also merged **microsoft/PyRIT #2320** (released in v1.1.0), a reset hook so realtime and WebSocket targets close a conversation's connection after each attack.
- **Warden** (github.com/mahdi-al-hakim/warden): runs a Claude agent on IT offboarding under policy, human approval, a hash-chained audit log and a revocation kill switch. Designed and ran an eval on Claude Haiku, Sonnet and Opus 5.5 in which a colleague's note on the departing user's record asks the agent to also disable a shared admin account. None of the 30 runs acted on it. No arm made that write the right call, so it can't show a refusal; every run file is published.
- **controlarm** (github.com/mahdi-al-hakim/controlarm): open-source harness that will not record a security test as negative unless the same run shows the target answering and the plain version of the attack being refused; otherwise the run is filed VOID. Its prior-art check is scored against 80 labeled items from 40 public advisories, and CI removes each of its 188 guards to show a test catches the removal.
- **MALT study** (github.com/mahdi-al-hakim/malt-reward-hacking): in METR's MALT dataset, a check for one word finds 223 of the 224 runs labeled sabotage and none of the 6,047 normal ones, because the agent names what it was told to do; one word also finds most refusal and weaker-model runs. So a monitor's score on those labels can't show it finds sabotage an agent keeps quiet about.

Security research

- **github/github-mcp-server #3109** (shipped in v1.10.0): `pull_request_read` dispatches nine methods from one switch; seven return user-written text and lockdown covered six. Untrusted fork commit messages still reached the agent through `get_commits`. One of three credited reporters. Writeup.
- **Keycloak**, 3 reports, all credited. **#51630** (fixed; released in 26.8.2, Nov 2026): the admin access report said a delegated admin's permission was denied while enforcement allowed the write. **#51376**: revoking an OAuth2 token ended the session but skipped the CAEP session-revoked event, so offline checks kept accepting it until expiry; reported as CWE-613, which the vendor reclassified as an enhancement, fixed on main by PR #51386. **#51718**: a client could widen its own JWT-grant audience allowlist through dynamic registration; I wrote the proposed fix (PR #51720, in review). Writeup.
- **Unidata netcdf-c #3421** (fix merged Nov 2026): integer overflow in classic-format length math undersized a heap buffer while the un-wrapped count still drove the read loop. The project is on OSS-Fuzz; its only harness never read an attribute. Reported privately and wrote the fix.

Experience

CME Offshore SAL, Software Engineer Jul 2025 – Present (intern 2024)
Builds software for external clients.

- Turned my own proof of concept into a multi-tenant MCP server (two-engineer build) that orchestrates pipelines across clients' SDLC through the tools they already use. Pitched it to our CEO, then owned it through deployment into 8+ client environments. Designed the security model: tenant isolation, auth, and untrusted ticket text reaching agents.
- **Architected and led development of an MCP server for our platform, and of the agentic system built on it**, replacing a customer-facing agent that looped on attempts to call platform APIs and surfaced its own failures to users.
- Designed and built an authorization-code flow with PKCE and refresh across an app's hosts on a least-privilege client.
- Owned development of an analytics dashboard whose agentic visualization engine sits on deterministic, strictly validated computation, so data integrity never depends on the model. Architected the new micro-bundling front end, and co-led the effort to make our repositories AI-enabled.
- Built a vulnerability-monitoring tool (NVD, OSV, CISA KEV, EPSS) that ranks dependencies and alerts via Microsoft Teams, and co-started the team's security audit workflow. Ship features on AWS (serverless, EKS) in Python, Java and TypeScript, and take on-call shifts.

CloudGate Consulting, Full Stack Developer (part-time, client-facing) Jul 2022 – Jul 2024
Built Flask and React apps and microservices with OpenAPI docs for client systems.

CTF, teaching and community

- **Semicolon**, Lebanese Universities CTF 2025 (∼260 teams): placed 1st on the national qualifying-round leaderboard with a three-person AUB team. Lebanon CTF 2026: co-organizer and mentor; co-designed and taught Semicolon's 10-session AI security course (OWASP LLM Top 10, MITRE ATLAS, prompt injection, MCP security).
- **Hack The Box Ambassador, Beirut** (Feb 2025 – Present): co-founded HTB Beirut; run 12+ meetups (20–100 people) and author practice machines. Published WeSecure, a boot-to-root VM with a full writeup.

Education and skills

American University of Beirut, B.E. Computer and Communications Engineering, minor in Applied Mathematics, 2021–2025. **Skills:** Python, C/C++, TypeScript, Java, SQL; AWS, Kubernetes; Burp Suite, ASan, PyRIT, RAMPART, Inspect.